

48730/32548, Cyber Security Lab 1, Part 1

Information Gathering and Extracting Unencrypted Data

The Tasks included in Lab – 1, Part 1 do not require VMware Workstation or VMware Fusion, Task 1 and Task 2 will require Wireshark. Wireshark is an open-source Packet analysing software. Wireshark can be downloaded from <https://www.wireshark.org/download.html> . Lab 1, Part 1 should be submitted along with Lab 1, Part 2 in Week 3 (refer to assignment section of the course on Canvas for the Due date). The assignment document should contain only questions from the lab manual, your answers and screenshots to support your answers.

Task 1: Sniff Login details from unencrypted HTTP traffic:

Data transmitted through HTTP is vulnerable to interception by malicious actors, who can potentially eavesdrop on unencrypted packets and extract sensitive information such as images, login credentials, or personal data. Therefore, cybersecurity professionals employ specialised tools and methodologies, like packet sniffers, to analyse network traffic, identify potential security gaps, and implement robust encryption measures, safeguarding data integrity and preserving user privacy.

In this practical lab, you will acquire fundamental information gathering skills using Wireshark. Through the analysis of captured network packets, you'll explore the extraction of valuable data transmitted over unencrypted HTTP connections. This hands-on experience will equip you with essential tools to identify and understand potential security risks and vulnerabilities, enhancing your expertise in cybersecurity information analysis.

Step 1:

- a. Open Wireshark and make sure that promiscuous mode is enabled on all interfaces.
- b. Start the capturing of files.
- c. Go to: <http://bias.csr.unibo.it/fvc2004/logon.asp>
- d. Enter **your name** /email as the login username and enter your name as the password. Make sure you hit the login button.



FVC2004	Logon to Participant Area
Home	User name (e-mail) ishan@ishan.com
Background	User password
Categories	Logon
Protocol	▶ Forgot your password?
Databases	▶ Questions or problems?
Perf. evaluation	
Participants	
Results	
Download	
Past editions	
FVC2000	
FVC2002	
Participant area	
Register	
Logon	

© 2003 Biometric System Lab - University of Bologna

Step 2:

- Utilise the search bar to locate the packet with the login information. [**Hint:** the packet will be using HTTP protocol and will start with POST].
- In Wireshark, locate the login details which are the username and the password you have used for the unsecure website.

This will look like:

```

▶ Hypertext Transfer Protocol
▼ HTML Form URL Encoded: application/x-www-form-urlencoded
  ▶ Form item: "id" = "ishqan@ishan.com"
  ▶ Form item: "pwd" = "ishan"

```

Hints:

Write **frame contains "POST"** in search bar of Wireshark to look for packet containing the login information.

Question:

- Submit a screenshot of the username and password from Wireshark.

Task 2: Extract an image form unencrypted HTTP packet

Wireshark and similar network sniffing tools, offers the ability to extract images from unencrypted packets transmitted via websites that use the HTTP protocol or other

unencrypted protocols. This capability allows experts to identify potential vulnerabilities, assess data leakage risks, and bolster network security, strengthening overall digital resilience and ensuring the protection of sensitive information effectively. In practice experts in industry use several tools to extract such information.

Steps:

You are tasked to extract the logo image of the same website (<http://bias.csr.unibo.it/fvc2004/login.asp>) we have entered previously. Use the same packets captured from task 1.

- a. Locate the GET packets that contains the “.gif” raw data. You may utilise the search bar like task 1.

Hints:

Write **frame contains "GET"** in search bar of Wireshark to look for packet containing the image information.

```
HTTP 499 GET /fvc2004/styles/fvc2004.css HTTP/1.1
HTTP 552 GET /fvc2004/Graphics/fvc2004_head.gif HTTP/1.1
HTTP 555 GET /fvc2004/graphics/bullet.gif HTTP/1.1
```

- b. Go to file > Export Objects > HTTP
- c. Download the object that contains the .gif extension.

Question:

- a. Take a screenshot of the HTTP object list that contain list of images received from the webpage.

Note: If the image file is not found on the HTTP object list, repeat the task by accessing the webpage on the web browser using incognito or private mode.

Task 3: Information Gathering

An ethical hacker is a computer and networking expert who systematically attempts to penetrate a computer system or network on behalf of its owners for the purpose of finding security vulnerabilities that a malicious hacker could potentially exploit.

Passive information gathering

A lot of important information can be passively gathered and subsequently used in a direct attack or to reinforce other attacks targeted at an organization. Some Web Hosting service providers provide Website analysis that may pose a risk to security of an organization.

Active information gathering

Unlike passive information gathering, active information gathering collects the most updated and current data. The information collected in this manner can be influenced by various factors that include your current location, ISP, network constraints, etc. This information can be used to investigate the current state of the target.

Zenmap

Zenmap or Nmap ("Network Mapper") is a free and open source (license) utility for network discovery and security auditing. It is useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime. Read more at www.nmap.org

NetCraft

Netcraft is an internet services company providing internet security services, including antifraud and anti-phishing services, application testing, code reviews, and automated penetration testing. It also provides research data and analysis on many aspects of the internet. Netcraft has explored the internet since 1995 and is a respected authority on the market share of web servers, operating systems, hosting providers, ISPs, encrypted transactions, electronic commerce, scripting languages and content technologies on the internet. Visit www.netcraft.com

Questions:

Using Zenmap and/or NetCraft to scan www.uts.edu.au. Gather and compare the information collected. Please use screenshots to support your answers.

1. What is its Ip address?
2. Type the IP address in the browser to access the webpage, explain your observations?
3. Who is the IP owner?
4. What is the server's operating system?
5. What type of web server is being used?
6. What is its server-side scripting technology?
7. Can you find the email for the domain admin of this website for a possible phishing attack?
8. What is the 'Reverse DNS' for the website?
9. Who is the domain registrar?
10. What is nameserver organization?
11. What company is hosting the website?
12. Where is the hosting company geologically located?

Information gathering can be achieved using various open-source intelligence tools. A list of such possible tools can be found at: <https://securitytrails.com/blog/osint-tools> As always, use the tools within a controlled safe environment.